

WPScan — دليل الاستخدام العملي

WordPress detection, users/plugins/themes enumeration, API token, output, و credential testing داخل Lab.

» [Abdullah Nasser Almsan – Personal Pentest Reference](#)

ملاحظة استخدام: عندك WordPress Cheat Sheet سابق؛ هذا الملف يركز على WPScan نفسها وخياراتها كأداة.

FOLLOW-UP
CVE/SearchSploit

VERSION
تحقق

ENUM
u/vp/vt

DETECT
WordPress

الفهرس

4. Credential testing داخل Lab
5. Output / troubleshooting
6. Workflow

1. ابدأ بإثباتات WordPress
2. Enumeration
3. Vulnerability data / API

1. ابدأ بإثباتات WordPress

لا تشغل WPScan على كل موقع عشوائيًا.

KALI TERMINAL Fingerprint

```
whatweb [URL]  
curl -I [URL]/wp-login.php
```

KALI TERMINAL Basic WPScan

```
wpscan --url [URL]
```

2. Enumeration

أهم -e options

الخيار	المعنى
u	Users
vp	Vulnerable plugins
ap	All plugins - أوسع

المعنى	الخيار
Vulnerable themes	vt
All themes - أوسع	at
Config backups	cb
DB exports	dbe

KALI TERMINAL Users

```
wpscan --url [URL] --enumerate u
```

KALI TERMINAL Plugins/themes

```
wpscan --url [URL] --enumerate vp,vt
```

KALI TERMINAL أوسع - عند الحاجة

```
wpscan --url [URL] --enumerate ap,at --plugins-detection mixed
```

ap/at قد ينتجان عددًا أكبر من الطلبات. ابدأ بأضيّق enumeration يكفي هدف اللاب.

Vulnerability data / API .3

بعض معلومات الثغرات تعتمد على API token.

KALI TERMINAL Token

```
wpscan --url [URL] --api-token [TOKEN]
```

حتى لو عرض WPScan vulnerability مرتبطة بمكوّن، تحقق من أن الإصدار المكتشف موثوق وأن شروط الاستغلال تنطبق.

Lab Credential testing .4

فقط إذا السيناريو يطلبه.

KALI TERMINAL User + wordlist

```
wpscan --url [URL] -U [USER_OR_LIST] -P [WORDLIST]
```

Password attacks قد تسبب lockout أو Traffic كبير. استخدمها فقط إذا Scope اللاب يسمح بذلك.

Output / troubleshooting .5

احفظ Evidence وافهم false negatives.

KALI TERMINAL Output

```
wpscan --url [URL] -o wpscan.txt
```

KALI TERMINAL Help / update

```
wpscan --help  
wpscan --update
```

KALI TERMINAL Burp إلى Proxy

```
wpscan --url [URL] --proxy http://127.0.0.1:8080
```

مفيد لفهم طلبات WPScan أو تشخيص النتيجة.

Workflow .6

WordPress → components → versions → finding

الخطوة	العمل	الهدف
1	Detect	أثبت WordPress
2	Base scan	إصدار/Theme/interesting findings
3	Enumerate	u / vp / vt حسب المطلوب
4	Version check	تأكد من المكوّن والإصدار
5	Search	SearchSploit/CVE/Metasploit إذا ينطبق
6	Validate	اختبار مصرح فقط

مرجع مراجعة سريع للتعلم والاختبارات المصرح بها فقط.

Refs: <https://github.com/wpscanteam/wpscan/wiki/WPScan-User-Documentation> · <https://github.com/wpscanteam/wpscan>